

İngiltere’de Enerji Tesisı Dört Gün Devre Dışı Kaldı: Siber Saldırıda Asıl Delil OT Kayıtlarında

24 Ağustos 2026 | Ankara | Melike Özlem BİLGİLİ - Adli Mühendis

İngiltere’de küçük ölçekli bir elektrik üretim tesisinin temmuz ayında gerçekleşen bir siber saldırının ardından dört gün boyunca devre dışı kaldığına ilişkin haberler, 24 Ağustos’ta hükümet ile enerji sektörü arasında üst düzey güvenlik temasına dönüştü. Reuters’a göre İngiliz hükümeti enerji şirketlerinin yöneticilerine olay ve siber tehditler konusunda brifing verdi. Tesisin adı ve yeri kamuya açıklanmadı.

İngiltere Enerji Güvenliği ve Net Sıfır Bakanlığı (DESNZ), olayın küçük ölçekli bir üreticiyi etkilediğini ve daha geniş enerji sistemi için risk oluşturmadığını bildirdi. Enerji Bakanı Michael Shanks da ulusal elektrik şebekesinde kesinti yaşanmadığını açıkladı. İran bağlantılı aktörlere ilişkin haberler bulunmakla birlikte Reuters, affın kesinleşmediğini aktarıyor. Bu nedenle saldırgan kimliği kamuya açık mevcut verilerle adli olarak doğrulanmış kabul edilemez.

DÖRT GÜNLÜK DURUŞ: ERİŞİM İLE ÜRETİM KAYBI AYNI ŞEY DEĞİL

Adli mühendislik bakımından kritik mesele, siber erişim ile dört günlük operasyon kaybı arasındaki nedensellik zinciridir. Saldırganın hangi sisteme eriştiği, IT ortamından OT/ICS ağına geçiş bulunup bulunmadığı, PLC/RTU/SCADA veya mühendislik istasyonlarında değişiklik yapıp yapılmadığı ve tesisin neden dört gün güvenli biçimde yeniden devreye alınamadığı ayrı ayrı kanıtlanmalıdır. İlk erişim araştırması; kullanıcı/VPN hesaplarının yanında üçüncü taraf uzaktan bakım bağlantıları, servis sağlayıcı erişimleri, jump host/bastion sistemleri, çift arayüzlü sunucular ve IT–OT arasında tasarım dışı köprü oluşturabilecek cihazları da kapsamalıdır.

Adli OT incelemede nedensellik zinciri



Metodolojik şema: olayın kamuya açıklanmayan gerçek ağ mimarisini temsil etmez.

Şekil 1. Adli OT incelemede önerilen nedensellik zinciri. Bu şema olayın gerçek ve kamuya açıklanmayan tesis mimarisini değil, inceleme metodolojisini gösterir.

ASIL DELİL: ZAMAN SENKRONLU IT–OT KAYIT ZİNCİRİ

Güvenlik duvarı, VPN, kimlik doğrulama, ayrıcalıklı hesap, EDR/SIEM ve uzak erişim kayıtları; mühendislik istasyonu imajları, PLC/RTU programları, SCADA alarm ve olay geçmişi, historian/proses verileri ve koruma sistemi kayıtlarıyla ortak zaman çizelgesinde korele edilmelidir. NTP ve diğer saat kaynakları doğrulanmadan farklı sistemlerdeki zaman damgalarının doğrudan eşleştirilmesi hatalı nedensellik yaratabilir.

Kontrol mantığında değişiklik iddiası varsa sahadaki mevcut program, olay öncesi güvenilir yedek ve proje dosyalarıyla karşılaştırılmalı; hash/checksum, firmware sürümü, logic/program değişiklikleri ve mühendislik yazılımı kayıtları birlikte değerlendirilmelidir. MITRE ATT&CK for ICS, doğrulanmış saldırgan davranışlarını sınıflandırmak için kullanılabilir. Execution, Inhibit Response Function ve Impair Process Control ICS matrisindeki gerçek taktiklerdir; ancak bunların varlığı somut olay deliliyle gösterilmelidir, matris tek başına saldırı kanıtı değildir.

IEC 62443: ZONES/CONDUITS 3-2'DE, SİSTEM GEREKSİNİMLERİ 3-3'TE

OT mimarisinin değerlendirilmesinde NIST SP 800-82 Rev. 3 ağ segmentasyonu ve izolasyon için güçlü bir teknik referanstır. ISA/IEC 62443-3-2:2020, incelenen IACS sisteminin zones ve conduits olarak bölünmesi, her bölge/iletişim yolu için risk değerlendirmesi ve hedef güvenlik seviyesinin belirlenmesine ilişkin gereksinimleri tanımlar. IEC 62443-3-3:2013 ise sistem güvenlik gereksinimleri ve güvenlik seviyelerine odaklanır. Purdue modeli mimariyi katmanlar halinde anlamaya yardımcı olabilen yaygın bir referans modelidir; IEC 62443-3-3'ün 'Purdue uyumluluğu' şartı koyduğu şeklinde sunulmamalıdır.

NIS 2018: 72 SAAT KURALI VAR, AMA ÖNCE OES STATÜSÜ VE EŞİK DOĞRULANMALI

Network and Information Systems Regulations 2018'in 10. maddesi OES'lere uygun ve orantılı teknik/organizasyonel güvenlik tedbirleri alma; 11. maddesi ise sağlanan temel hizmetin sürekliliği üzerinde önemli etkisi bulunan NIS olaylarını yetkili otoriteye bildirme yükümlülüğü getirir. Regulation 11(3)(b) uyarınca bildirim, gereksiz gecikme olmaksızın ve işletmecinin NIS olayından haberdar olmasından itibaren en geç 72 saat içinde yapılmalıdır.

Great Britain downstream gaz ve elektrik sektörüne ilişkin Ofgem'in Ocak 2026'da güncellenen OES rehberi de, bildirim eşiğini karşılayan olayların Ofgem'e gereksiz gecikme olmaksızın ve en geç 72 saat içinde bildirilmesini açıkça belirtir; Ofgem bildirim DESNZ ve NCSC ile paylaşır. Bu ayrıntı önemlidir: yürürlükteki düzenlemede OES'nin zorunlu bildiriminin muhatabı ilgili competent authority'dir. NCSC'nin rolü CSIRT/teknik otorite niteliğindedir.

Bununla birlikte kamuya açıklanmayan bu küçük üretim tesisinin OES statüsü ve somut olayın NIS bildirim eşiğini karşılayıp karşılamadığı doğrulanmış değildir. Bu nedenle olay özelinde 'Ofgem'e 72 saat içinde bildirim yapmak zorundaydı' sonucu kurulamaz; önce tesisin hukuki kapsamı belirlenmelidir. Ayrıca Haziran 2026 tarihli Cyber Security and Resilience Bill factsheet'inde yer alan 24 saatlik ilk bildirim + 72 saatlik ayrıntılı rapor modeli, yürürlükteki NIS 2018'deki mevcut 72 saatlik bildirim kuralıyla karıştırılmamalıdır.

MEVCUT KURAL İLE ÖNERİLEN YENİ MODEL

Başlık	Yürürlükteki NIS 2018	Cyber Security and Resilience Bill önerisi
Kapsam	OES ve ilgili NIS kapsamındaki kuruluşlar	Kapsamı ve raporlanabilir olay türlerini genişletmeyi amaçlayan reform
İlk bildirim	Eşiği karşılayan NIS olayı: gereksiz gecikme olmaksızın, en geç 72 saat	İlk, hafif bildirim: 24 saat
Devam raporu	Yetkili otorite rehberine göre olay yönetimi/izleme raporları	Daha ayrıntılı rapor: 72 saat
Enerji OES muhatabı	Uygulanabilir sektörde competent authority; downstream gaz/elektrikte Ofgem rehberi	Regülatör ve aynı zamanda NCSC'nin bilgilendirilmesi öngörülüyor

DÖRT GÜNÜN NE KADARI SALDIRI, NE KADARI GÜVENLİ GERİ DÖNÜŞ?

Tesisin kapalı kalma süresi saldırganın kontrol süresiyle aynı olmak zorunda değildir. Sistem izolasyonu, adli imaj alma, güvenilir yedeklerin doğrulanması, PLC/RTU firmware bütünlüğünün üretici tarafından desteklenen yöntemlerle kontrol edilmesi, şüpheli bileşenlerin güvenilir kaynaktan yeniden kurulması, konfigürasyon ve logic doğrulanması, proses güvenliği testleri ve kontrollü yeniden devreye alma da duruş süresine dahil olabilir. 'Firmware sterilizasyonu' gibi belirsiz bir ifade yerine hangi bileşenin hangi güvenilir referansa göre doğrulandığı ve yeniden yüklendiğinin belgelenmesi daha denetlenebilir.

BİLİRKİŞİ VE ADLİ MÜHENDİSLİK İNCELEME YÖNERGESİ

1. İlk yetkisiz erişimin tarihi, hesabı, IP/cihazı ve erişim yolu; üçüncü taraf bakım ve tedarik zinciri bağlantıları dahil belirlenmeli.
2. Olay tarihindeki IT-OT topolojisi, güvenlik duvarı kuralları, OT DMZ, jump host'lar, çift arayüzlü sistemler ve uzaktan erişim yolları çıkarılmalı.
3. NTP/saat kaynakları doğrulanarak IT güvenlik logları, SCADA/PLC/RTU olayları, historian ve koruma sistemi kayıtları ortak zaman çizelgesinde korele edilmeli.
4. PLC, RTU, SCADA, HMI ve mühendislik istasyonları güvenilir olay öncesi yedeklerle logic, konfigürasyon, firmware ve hash/checksum bakımından karşılaştırılmalı.
5. Duruşa saldırgan komutu/mantık müdahalesinin mi, trip/ESD gibi koruma fonksiyonlarının mı, yoksa işletmecinin güvenlik amaçlı kontrollü kapatma kararının mı yol açtığı ayrıştırılmalı.
6. Yeniden devreye alma öncesi bütünlük doğrulanması, güvenilir kaynaktan geri yükleme ve proses güvenliği testleri kayıt altına alınmalı.
7. MITRE ATT&CK for ICS yalnız doğrulanmış davranışların sınıflandırılması ve delil boşluklarının görülmesi için kullanılmalı.
8. İşletmecinin NIS 2018 kapsamında OES olup olmadığı, olayın bildirim eşiği ve varsa competent authority bildirim zamanı resmi kayıtlarla kontrol edilmeli.
9. Dört günlük duruş; doğrudan saldırı etkisi, izolasyon, adli inceleme, geri yükleme, bütünlük doğrulanması ve güvenli devreye alma sürelerine ayrılmalı.
10. Üretim kaybı hesabında karşı-olgusal üretim, tesis kullanılabilirliği/taahhütleri, gerçekleşen piyasa koşulları, kaçınılan yakıt ve değişken işletme giderleri ile zorunlu kurtarma giderleri ayrı gösterilmeli.

SİGORTA VE RÜCUDA TEKNİK NEDENSELLİK POLİÇE YORUMUNDAN AYRILMALI

Dört günlük takvim süresinin tamamı otomatik olarak tazmin edilebilir zarar değildir. Fiziksel hasar, bekleme süresi, siber olay kapsamı ve istisnalar ile devlet destekli aktör/savaş bağlantılı klostların uygulanması somut poliçe metnine göre değerlendirilir. Teknik bilirkişi saldırganın siyasi kimliği veya poliçe hukukunun sonucu hakkında hüküm kurmamalı; doğrulanabilir teknik olayları, operasyonel sonuçları ve yeniden üretilebilir zarar hesabının girdilerini ortaya koymalıdır.

SONUÇ

Bu olayın adli mühendislik değeri saldırganın adından çok, siber erişim ile fiziksel üretim kaybı arasındaki zincirin nasıl kanıtlanacağı sorusunda yatıyor. Tesisin kimliği, saldırı vektörü ve ayrıntılı teknik etki zinciri kamuya açıklanmış değil. Bu nedenle güvenilir bir inceleme; siyasi atıftan önce dijital delil bütünlüğünü, IT–OT geçişini, kontrol mantığı ve firmware bütünlüğünü, proses kayıtlarını, güvenli yeniden devreye alma süresini ve gerçek üretim kaybını ortaya koymalıdır.

DOĞRULANMIŞ KAYNAKLAR

- Reuters, 24 Ağustos 2026, “UK briefs energy chiefs after Iran-linked cyber attack reports.”
- The Network and Information Systems Regulations 2018, SI 2018/506, Regulations 10–11, legislation.gov.uk.
- Ofgem, “NIS Guidance for Downstream Gas and Electricity Operators of Essential Services in Great Britain v3.0”, Ocak 2026 güncellemesi; özellikle §§9.7–9.10.
- GOV.UK / DESNZ, “Implementation of the Network and Information Systems Regulations 2018 for the energy sector in Great Britain.”
- GOV.UK, “Cyber Security and Resilience Bill – Incident reporting”, 30 Haziran 2026.
- NIST SP 800-82 Rev. 3, “Guide to Operational Technology (OT) Security”, Eylül 2023; özellikle §6.2.1.3 Network Segmentation and Isolation.
- IEC 62443-3-2:2020, “Security risk assessment for system design.”
- IEC 62443-3-3:2013, “System security requirements and security levels.”
- MITRE ATT&CK for ICS, ICS tactics/matrix.